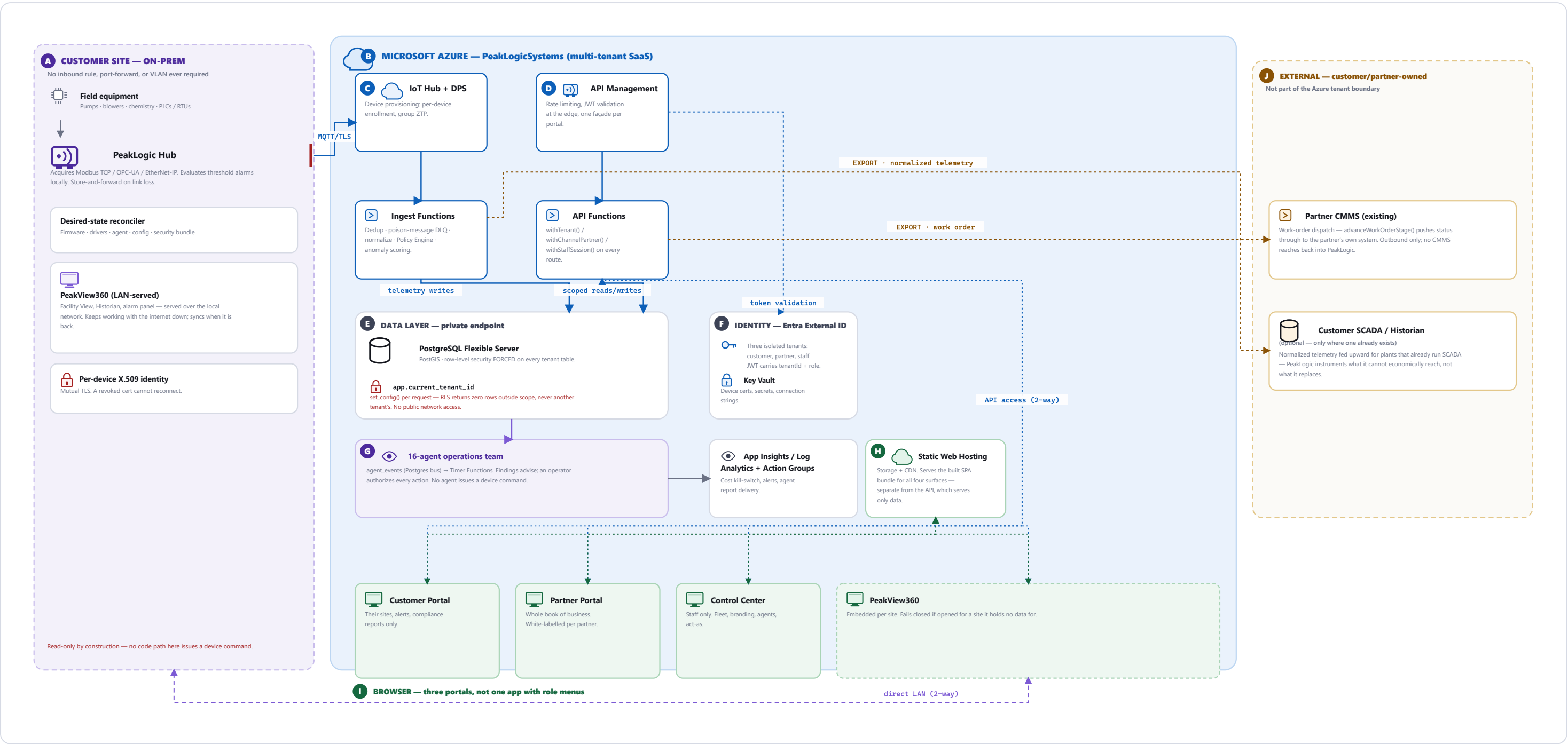


PeakLogic platform — system & data-flow diagram

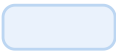
Azure-native, multi-tenant. Every arrow below is a real data flow; every dashed boundary is an enforced isolation boundary, not an aspiration. Prepared for architectural and security review.



Reading the diagram

A fixed vocabulary of shapes, used consistently, plus a lettered badge on every boundary — cross-referenced below — so a review conversation can say "look at E" instead of re-pointing at the screen. One honest limitation: these are hand-drawn analogues of the well-known Azure shapes, not Microsoft's own licensed icon set, which this document's build process has no way to embed.

Boundaries

	On-prem boundary — the customer's own network. Nothing inside requires an inbound rule from the cloud.
	Azure tenant boundary — every managed service PeakLogic operates.
	Private sub-boundary — data layer (no public network access) and identity.
	External ownership boundary — the partner's CMMS, a customer's own SCADA. Not part of the Azure tenant.

Icons

	Gateway — PeakLogic Hub, on-prem edge acquisition
	Managed cloud service — Azure PaaS component
	Database — PostgreSQL Flexible Server
	Serverless function — Azure Functions
	Security control — identity, encryption, secrets
	User-facing surface — a portal or operator view

Flow lines

	Solid — telemetry / data write path, always active, one direction only
	Dashed, both ends arrowed — a genuine request/response round trip (browser↔API, LAN path)
	Dashed, one arrow — a one-way check, e.g. token validation
	Green dashed — static-asset delivery (SPA hosting), distinct from API data calls
	Amber dashed — export to a system the customer or partner already owns, deliberately one-way by design
	Blocked stub — a path that does not exist today (see Roadmap)

Domain reference

Every lettered badge on page 1, in one place.

A Customer site (on-prem) Field equipment, PeakLogic Hub, LAN-served PeakView360	B Microsoft Azure The overall multi-tenant SaaS boundary — everything below is inside it except J	C Device ingest IoT Hub/DPS + Ingest Functions — provisioning and telemetry	D API layer API Management + API Functions — every portal request	E Data layer PostgreSQL Flexible Server, RLS-forced, private endpoint
F Identity Entra External ID (3 tenants) + Key Vault	G Operations 16-agent team + App Insights/Log Analytics/Action Groups	H Static hosting Storage + CDN serving the built SPA bundle	I Browser surfaces Customer Portal, Partner Portal, Control Center, PeakView360	J External systems Partner's CMMS, customer's own SCADA — not PeakLogic's

What a reviewer should take away

FLOW	PATH	SECURITY CONTROL
Telemetry ingest	Equipment → Hub → IoT Hub/DPS → Ingest Functions → PostgreSQL	MTLS per-device X.509 cert, outbound-only session, no inbound firewall rule ever required on the customer network. One direction only
Operator / customer request	Browser ⇌ APIM ⇌ API Functions ⇌ PostgreSQL	ENTRA JWT validated at APIM; every route wrapped in withTenant() / withChannelPartner() / withStaffSession(), which activates PostgreSQL row-level security. Genuine round trip — request and response
Static asset delivery	Browser → Storage + CDN (Static Web Hosting)	Separate from the API path above — this serves the SPA's code, not its data. No auth gate needed; nothing here is tenant-scoped
PeakView360 (embedded)	Portal iframe ⇌ Hub, direct over the site LAN, when opened on-site	Fail-closed scope guard — refuses to render if it holds no data for the requested site, rather than falling back to another site's facility. Two-way
Agent operations	PostgreSQL event bus → Timer Functions → Action Groups (email) / audit log	Findings carry tenant_id and are RLS-scoped. Agents propose only — every action needs operator authorization, logged to that operator, never to the agent
Work-order dispatch (export)	API Functions → PARTNER CMMS , outbound only	advanceWorkOrderStage() pushes ticket status through to the partner's own CMMS. Nothing in that system calls back into PeakLogic — the trust direction is one-way
Telemetry export (optional)	Ingest Functions → CUSTOMER SCADA/HISTORIAN , where one already exists	Normalized telemetry only, fed upward — PeakLogic instruments the long tail an existing SCADA cannot economically reach, it does not replace safety-rated control logic
Command / actuation	NOT BUILT	No code path publishes a device command today. The network model (outbound MQTT/TLS, per-device topic) already supports it; authorization, safety interlocks and audit trail are designed before any command path is opened

Tenant isolation

Every tenant-scoped query runs inside a transaction that sets `app.current_tenant_id` via `set_config()`, activating PostgreSQL RLS — **forced**, not merely enabled, and with no `BYPASSRLS` role. A site outside a viewer's scope is refused, never approximated.

Deployment reality

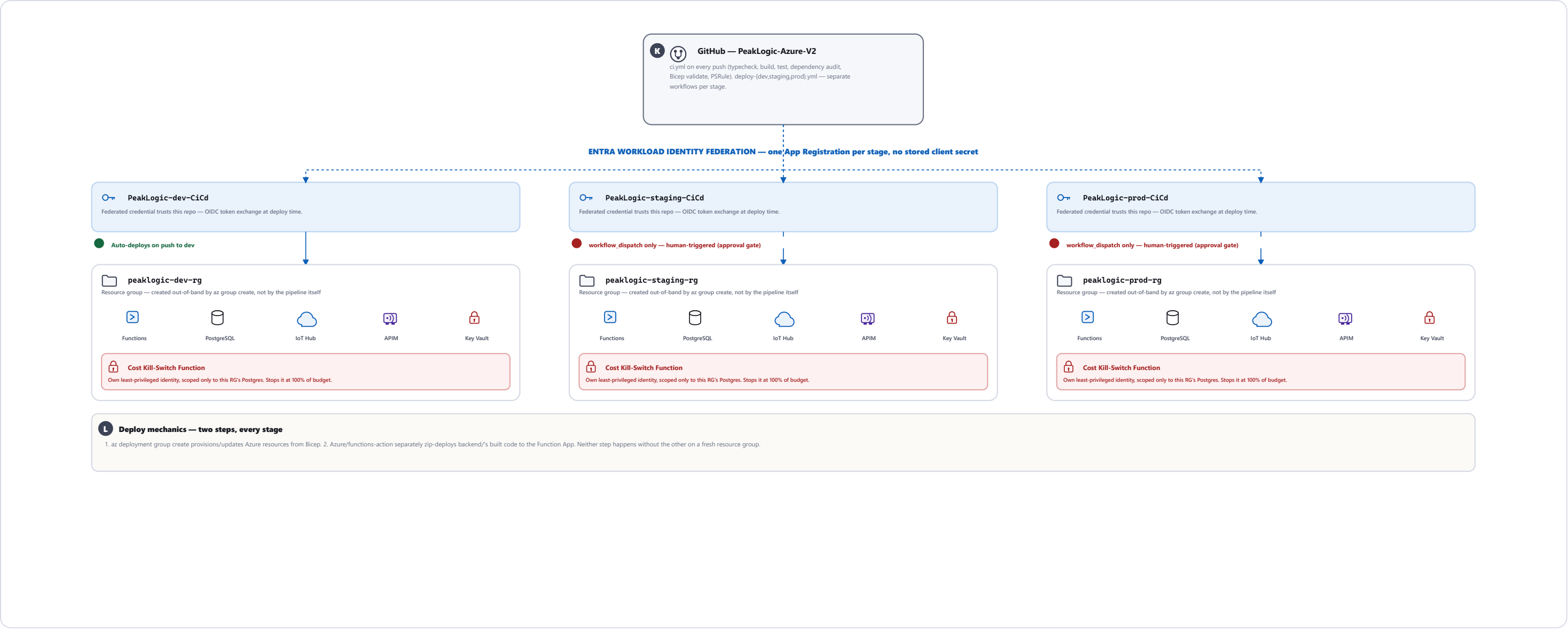
Defined in Bicep, validated by `az bicep build` and `PSRule` on every push. **NO ENVIRONMENT DEPLOYED YET** — this diagram describes the architecture as designed and CI-validated, not a running production system.

Cost containment

A dedicated Cost Kill-Switch Function (its own least-privileged identity, scoped only to the Postgres resource) stops the database at 100% of budget. Agents run on the existing consumption plan — additive spend is near \$0.

How the Azure tenant itself is organised

A different question from pages 1–3: not how the application's data moves, but how the account, identity-for-deployment, and CI/CD path are structured. Single subscription today, one resource group per stage — matches this project's cost-conscious MVP posture everywhere else (documented in CLAUDE.md's Environments/Deployment Stages section).



NOT DEPLOYED No environment has been created yet — peaklogic-{dev,staging,prod}-rg, the Entra App Registrations, and the federated credentials are all still to-do, not running infrastructure. This page describes the designed target, same disclosure as pages 1–3.